app access to just those files, without needing a complicated consent process.

Confused deputies and ambient authority

Many common vulnerabilities in APIs and other software are variations on what is known as a *confused deputy* attack, such as the CSRF attacks discussed in chapter 4, but many kinds of injection attack and XSS are also caused by the same issue. The problem occurs when a process is authorized to act with your authority (as your "deputy"), but an attacker can trick that process to carry out malicious actions. The original confused deputy (http://cap-lore.com/CapTheory/ConfusedDeputy.html) was a compiler running on a shared computer. Users could submit jobs to the compiler and provide the name of an output file to store the result to. The compiler would also keep a record of each job for billing purposes. Somebody realized that they could provide the name of the billing file as the output file and the compiler would happily overwrite it, losing all records of who had done what. The compiler had permissions to write to any file and this could be abused to overwrite a file that the user themselves could not access.

In CSRF the deputy is your browser that has been given a session cookie after you logged in. When you make requests to the API from JavaScript, the browser automatically adds the cookie to authenticate the requests. The problem is that if a malicious website makes requests to your API, then the browser will also attach the cookie to those requests, unless you take additional steps to prevent that (such as the anti-CSRF measures in chapter 4). Session cookies are an example of *ambient authority*: the cookie forms part of the environment in which a web page runs and is transparently added to requests. Capability-based security aims to remove all sources of ambient authority and instead require that each request is specifically authorized according to POLA.

DEFINITION When the permission to perform an action is automatically granted to all requests that originate from a given environment this is known as ***ambient authority***. Examples of ambient authority